

GRC102

Week 3 Practical Laboratory

Roles, Responsibilities and Accountability in Security Governance

Name: Khadija Nafale Likoro

Reg. Number: C11_CGRCE_17281

Course: GRC102 Lab

TechGlobal Governance Transformation Simulation

1. Task 1: Governance Architecture and Stakeholder Map

1.1 Governance Gap Assessment

TechGlobal currently relies heavily on informal security decision making. The IT Director is carrying several security responsibilities at the same time, while formal governance forums and reliable escalation routes are missing. This creates several governance gaps.

Current weakness	Business or risk consequence
Security decisions are concentrated with the IT Director	Authority is concentrated in one role, reducing independent challenge and oversight.
There is no formal governance committee structure	Security decisions may be inconsistent and cross functional issues may not be resolved through a common forum.
Business units make local security choices	Different offices or business units may apply security controls differently.
The CEO and Board have limited visibility into cyber risk	Material risks may not receive timely executive or Board attention.
There are no reliable escalation paths	Important risks can remain at operational level instead of reaching the appropriate decision maker.

1.2 Stakeholder Map

Stakeholder	Authority and influence	Primary interest	Information needed	Governance contribution
Board	High	Risk appetite, assurance and accountability	Material cyber risks and assurance information	Oversight and challenge
CEO	High	Strategic alignment and business performance	Major security risks and business impact	Executive accountability
CISO	High	Security governance and programme effectiveness	Security posture, risks and control performance	Security leadership
CRO or Risk	High	Enterprise risk integration	Risk assessments and treatment status	Risk methodology and challenge
Legal and Compliance	Medium to High	Legal and regulatory duties	Privacy, contracts, evidence and notification issues	Legal and compliance advice
Finance	Medium to High	Budget and financial exposure	Security costs, losses and investment needs	Financial governance
HR	Medium	People governance	Joiner, mover and leaver controls, awareness and conduct	People related controls
IT or Technology	High operationally	Secure technology delivery	Technical risks and control status	Implementation and technical control ownership
Business Unit Leaders	Medium	Operational performance and local risk	Business risks and control requirements	Business ownership and implementation

1.3 Security Governance Organisation Chart

Board of Directors



CEO



Security Governance Oversight

CISO and CRO or Risk work with the Executive Security Council and Security Governance Committee.



Security Governance Committee

CISO, CRO or Risk, Legal, Finance, HR, IT and Business Unit representatives.



Operational delivery

IT and Business Units implement approved controls and report security issues through the agreed governance channels.

1.4 Consultant Justification

The proposed model separates strategic oversight, security leadership, enterprise risk management and technical implementation. This is appropriate for an organisation of approximately 2,500 employees operating across five global offices because a single IT centred decision model is unlikely to provide enough cross functional oversight. The structure gives the Board and CEO visibility into material cyber risk while allowing operational teams to continue making day to day technical decisions within approved boundaries.

The model also creates a route for business units to participate in governance without creating separate security silos. The CISO provides security leadership, the CRO or Risk function provides enterprise risk integration, and the Security Governance Committee provides a regular forum for decisions involving technology, legal, finance, HR and business operations.

2. Task 2: Governance Responsibility and Authority Matrix

2.1 Responsibility Matrix

Role	Purpose	Key governance responsibilities	Decision authority	Reports or escalates to	Performance indicators
Board	Provide oversight and accountability	Set oversight expectations and review material cyber risk	Board level oversight and material risk decisions	Receives material cyber risk reporting	Timely review of material risks; completion of oversight actions
CEO	Provide executive accountability	Align security with strategy and business performance	Executive decisions and risk acceptance within mandate	Board	Strategic security objectives achieved; timely executive decisions
CISO	Lead security governance	Security strategy, policies, risk oversight and programme effectiveness	Security governance decisions within approved mandate	CEO and relevant governance forums	Policy compliance; security programme progress
CRO or Risk	Integrate cyber risk into enterprise risk management	Risk methodology, risk acceptance, treatment and aggregation	Risk challenge and enterprise risk decisions within mandate	CEO and Board risk oversight	Risk assessments completed; treatment tracking
Legal	Provide legal and regulatory advice	Regulatory duties, contracts, privacy, evidence and notification advice	Legal advice and compliance interpretation	CEO, CISO and governance forums	Timely legal reviews; regulatory obligations tracked
Finance	Provide financial governance	Budget, loss exposure and investment prioritisation	Financial approval within delegated authority	CEO and governance forums	Budget control; investment tracking
HR	Provide people governance	Joiner, mover and leaver controls, awareness and conduct	People process decisions within mandate	CEO and governance forums	Access lifecycle completion; awareness participation
IT	Deliver and operate technology securely	Technical controls, secure operation and continuity	Technical implementation within approved standards	CISO and governance forums	Remediation performance; service continuity

2.2 Conflict Resolution Note

Potential overlaps include security governance versus technical implementation, enterprise risk acceptance versus business ownership, and legal advice versus executive decision making. The governance model should resolve these overlaps by separating advice from final decision authority, using documented approval thresholds, and ensuring that operational owners do not independently approve their own material risk without appropriate challenge.

For example, IT can implement a security control, but governance approval should remain with the appropriate security or executive authority. Business owners can identify and manage operational risk, while the risk function provides independent challenge and aggregation. Legal provides advice on regulatory and contractual requirements, while authorised executives or the Board make the final business decision where required.

3. Task 3: Security Governance Committee Ecosystem

3.1 Committee Structure

The governance ecosystem consists of three connected levels.

Executive Security Council

Provides strategic oversight of significant cyber risk, security investment and business alignment. It includes the CEO, CISO, CRO or Risk, Finance, Legal and IT leadership.

Security Governance Committee

Provides cross functional governance for policies, risk treatment, security architecture, third party risk, awareness, continuity and other recurring matters. Business Unit representatives participate so that security decisions remain aligned with operational needs.

Incident Response Working Group

Coordinates preparation and governance for significant incidents. It brings together security, IT, Legal, Communications or relevant business representatives and escalates material issues through the agreed route.

3.2 Committee Interaction

Operational teams identify issues and provide evidence to the Security Governance Committee. The committee resolves matters within its authority and escalates significant risks to the Executive Security Council. Where a risk is material to the organisation, the Executive Security Council ensures that the Board receives the required information and decision request.

3.3 Terms of Reference

- Purpose: provide a consistent cross functional forum for security governance decisions.
- Membership: CISO as chair, CRO or Risk, IT, Legal, Finance, HR and Business Unit representatives.
- Meetings: monthly, with extraordinary meetings when material risks require urgent review.
- Responsibilities: review cyber risk, policy, security investment, architecture, third party risk, incident governance and continuity matters.
- Decision making: decisions are recorded with an owner, rationale, actions and review date.
- Escalation: matters outside the committee mandate or meeting materiality criteria are escalated to executive management and, where material, to the Board.

3.4 Sample Committee Agenda

Agenda item	Purpose
Opening and previous actions	Confirm outstanding actions and previous decisions.
Cyber risk update	Review current material and emerging risks.
Security programme status	Review progress against security objectives.
Policy and compliance matters	Review significant policy or compliance issues.
Technology and architecture	Review major security architecture decisions.
Incident and resilience update	Review incidents, lessons and continuity readiness.
Decisions and escalations	Confirm decisions, owners and escalation requirements.

3.5 Sample Decision Log

Date	Decision or issue	Decision owner	Rationale	Action and owner	Review date
25 Sep 2026	Approve monthly cross functional security governance meeting	CISO	Formal governance is needed to coordinate security decisions	CISO to establish meeting schedule	Monthly

Date	Decision or issue	Decision owner	Rationale	Action and owner	Review date
25 Sep 2026	Require material cyber risks to be escalated through defined thresholds	CRO or Risk	Consistent escalation improves visibility and accountability	Risk function to maintain threshold register	Quarterly
25 Sep 2026	Introduce formal decision records for significant security decisions	CISO	Creates an auditable decision trail	Committee secretary to maintain decision log	Quarterly

3.6 12 Month Governance Calendar

Month	Recurring governance activity	Key milestone
Month 1	Committee setup and baseline review	Approve Terms of Reference
Month 2	Risk and policy review	Confirm risk reporting format
Month 3	Architecture and access governance	Review access governance
Month 4	Third party risk review	Review high risk suppliers
Month 5	Security awareness review	Review awareness participation
Month 6	Mid year governance review	Assess progress and actions
Month 7	Incident governance exercise	Review escalation readiness
Month 8	Business continuity review	Review recovery governance
Month 9	Risk treatment review	Review overdue treatments
Month 10	Security investment review	Review budget priorities
Month 11	Board reporting preparation	Prepare annual cyber risk summary
Month 12	Annual governance review	Refresh governance plan and objectives

4. Task 4: RACI Accountability Matrix

R means Responsible, A means Accountable, C means Consulted and I means Informed. The matrix is designed so that each activity has a clear accountable role wherever practicable.

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	I	A	R	C	C	I	I	C	C
Security policy approval	I	A	R	C	C	I	C	C	C
Enterprise cyber-risk assessment	I	I	R	A	C	I	C	C	C
Risk acceptance	I	A	C	R	C	I	I	C	C
Security budget approval	I	A	R	C	I	C	I	C	C
Security architecture approval	I	I	A	C	C	I	I	R	C
Third-party security review	I	I	A	C	C	I	I	R	C
Access governance	I	I	A	C	C	I	I	R	C
Incident response governance	I	C	A	C	C	I	C	R	C
Material incident escalation	A	R	R	C	C	I	I	R	C
Regulatory notification decision	I	A	C	C	R	I	I	C	I
Security awareness programme	I	I	A	C	C	I	R	C	C
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	C
Business continuity or recovery governance	I	A	C	C	C	C	C	R	C
Board cyber-risk reporting	A	R	R	C	C	I	I	C	C

4.1 RACI Implementation Guide

Managers should use the RACI matrix during planning to identify the accountable decision maker before work begins. During approvals, the responsible team prepares the work and the accountable role confirms the decision. Consulted stakeholders provide relevant advice before the decision is finalised. In incidents, the matrix helps teams identify who must act, who has authority to decide and who must be informed.

4.2 Problematic Assignments to Watch

First, combining operational implementation with final approval can weaken independence. Second, allowing a business owner to accept a material risk without risk function challenge can reduce independent oversight. Third, treating the IT function as the sole owner of security governance can recreate the concentration of authority described in the scenario. These issues should be addressed through the governance structure and approval thresholds.

5. Task 5: Cyber Risk Escalation and Segregation of Duties

5.1 Major Cyber Risk Escalation Workflow

Step 1: An operational team identifies or detects a cyber risk.

Step 2: The issue is assessed for business impact, security impact and urgency.

Step 3: The issue is assigned to the appropriate escalation level.

Step 4: Operational matters are managed by the operational owner. Significant matters move to executive management.

Step 5: Material risks are escalated to the Board through the agreed executive route.

Step 6: The decision, rationale, actions and review date are recorded.

Step 7: Actions are monitored until the issue is formally closed.

5.2 Escalation Threshold Table

Level	Example trigger	Decision authority	Notification	Target response
Level 1: Operational	Issue is within approved operational tolerance and has limited business impact	Operational owner with CISO or IT oversight as appropriate	Relevant operational team	Prompt operational handling
Level 2: Executive	Significant business impact, repeated control failure or risk beyond operational tolerance	CEO and relevant executive governance authority	CEO, CISO and CRO or Risk	Urgent executive review
Level 3: Material or Board	Material cyber risk, major business impact, significant regulatory or organisational consequence	CEO and Board as appropriate	Board and relevant senior stakeholders	Immediate escalation and decision

5.3 Segregation of Duties and Accountability Weakness Register

ID	Weakness or conflict	Risk created	Recommended control	Review
1	One IT leader effectively owns security, risk approval and operational decisions	Excessive concentration of authority	Separate governance approval from technical implementation	Quarterly
2	A control implementer could also approve the same control	Limited independent challenge	Require independent review or approval	Quarterly
3	Operational owners may accept their own material risks	Risk may be accepted without sufficient challenge	Require CRO or Risk review and defined approval thresholds	Quarterly
4	Business units make local security choices without common governance	Inconsistent control application	Use enterprise security standards and committee oversight	Six monthly
5	Board has limited visibility into cyber risk	Material risk may not reach oversight level	Provide regular Board cyber risk reporting	Quarterly

5.4 Decision Recording and Assurance Note

Significant governance decisions should be recorded in a central decision log. Each record should identify the date, issue, decision owner, decision rationale, actions, action owner and review date. The log should be reviewed periodically by the Security Governance Committee. Closed decisions should retain sufficient evidence to demonstrate what was decided, why it was decided and whether agreed actions were completed. This creates an auditable decision trail and supports later assurance activity.

6. Conclusion

The proposed governance model addresses the weaknesses in TechGlobal's informal and IT centred security model by clarifying roles, separating governance from implementation, establishing cross functional committees, defining accountability through RACI and creating a consistent cyber risk escalation route. It also gives the executive team and Board a clearer view of material cyber risk while allowing operational teams to manage day to day security activities within defined authority.

7. Supporting Evidence Bundles

Evidence Bundle 1: Governance gap assessment, stakeholder map, organisation chart and consultant justification.

Evidence Bundle 2: Governance responsibility matrix, role profiles and conflict resolution note.

Evidence Bundle 3: Committee ecosystem, Terms of Reference, agenda, decision log and 12 month governance calendar.

Evidence Bundle 4: RACI matrix and implementation guide.

Evidence Bundle 5: Cyber risk escalation workflow and threshold table.

Evidence Bundle 6: Segregation of Duties or Accountability Weakness Register and assurance note.

8. Source Basis

This report is based on the GRC102 Week 3 Practical Laboratory brief provided for the TechGlobal Governance Transformation Simulation. The brief requires a written report with supporting governance artefacts, including the six evidence bundles described above.